CS 6338 | KNOWLEDGE ENGINEERING | MILESTONE 1

ThreatWeave

An Intelligent GraphRAG Chatbot for Multi-Hop Cyber Threat Intelligence Analysis

Project proposal | Stephen Butler | sbutler6@angelo.edu

1. Team & Role Distribution

Team name: ThreatWeave. I will complete this instructor-approved individual project and be responsible for all four workstreams below. Scope is limited to a curated corpus and seven entity classes so that implementation, verification, and evaluation remain feasible.

Workstream / owner	Responsibilities
Data & Annotation / Stephen Butler	Corpus selection, evidence annotation, gold triples, and QA benchmark.
Graph Extraction & Reasoning / Stephen Butler	Ontology, LLM extraction, entity resolution, ATT&CK fusion, verification.
Embedding & Retrieval / Stephen Butler	Text and Node2Vec embeddings, indexes, multi-hop hybrid retrieval.
Evaluation & UI / Stephen Butler	Baseline and ablations, automated and human scoring, Streamlit, reports.

2. Problem Statement & Domain Context

Cyber threat intelligence (CTI) analysts and incident responders must connect evidence spread across advisories: which groups use particular software, which techniques that software implements, and which mitigations address those techniques. Semantic similarity can locate relevant passages, but it does not explicitly enforce the relationships needed to join facts across sources.

ThreatWeave will combine text retrieval with a provenance-aware knowledge graph. An illustrative query is: *Which software is linked to a selected threat group, which techniques does that software use, and which mitigations address those techniques?* Its evidence path is **ThreatGroup - Software - Technique - Mitigation**. Every answer will expose the supporting passages and retrieved paths.

Research question. Does hybrid text-and-graph retrieval improve factuality, completeness, and faithfulness on multi-hop CTI questions compared with text-only vector RAG? The project will test this hypothesis rather than presume an improvement. Broad CVE integration, custom GNNs, and operational threat detection are outside scope.

3. Dataset & Ground-Truth Annotation Strategy

Corpus. I will curate 15-25 public CISA advisories [1]. Initial candidates are AA23-075A (LockBit 3.0), AA23-165A (LockBit threat actors), and AA23-061A (Royal, March 2023). Their actor, software, technique, and mitigation content provides a starting point for testing cross-report links. I will confirm overlap in a five-report pilot, record URLs/dates/hashes, remove boilerplate, and preserve evidence offsets. Public sources will retain attribution and applicable use terms.

Structured reference. I will pin an ATT&CK Enterprise STIX 2.1 release [2], importing relevant IDs, aliases, and relations with release metadata. ATT&CK supports entity resolution and enrichment; it does not establish what a CISA passage states. I will freeze source versions before evaluation and keep actor identities distinct from similarly named malware.

Gold annotations. I will exhaustively label in-scope relations in selected held-out passages, yielding **50+ verified triples**, separate from prompt-development examples. Each label will include canonical endpoints, predicate, exact evidence, source/chunk IDs, and review notes. I will recheck labels against the source in a second pass and flag ambiguous passages before freezing the test set. Exhaustive labels within that set support valid precision and recall.

QA benchmark. I will freeze **20+ held-out, two- or three-hop questions**: at least eight actor/software/technique, eight technique/mitigation, and four cross-report comparison questions. Each will have required answer facts, evidence IDs, and expected paths. Separate development questions will guide tuning; test answers will never enter the index. Campaign questions will be included only when attribution is explicit.

4. Target Knowledge Graph Schema & Ontology Design

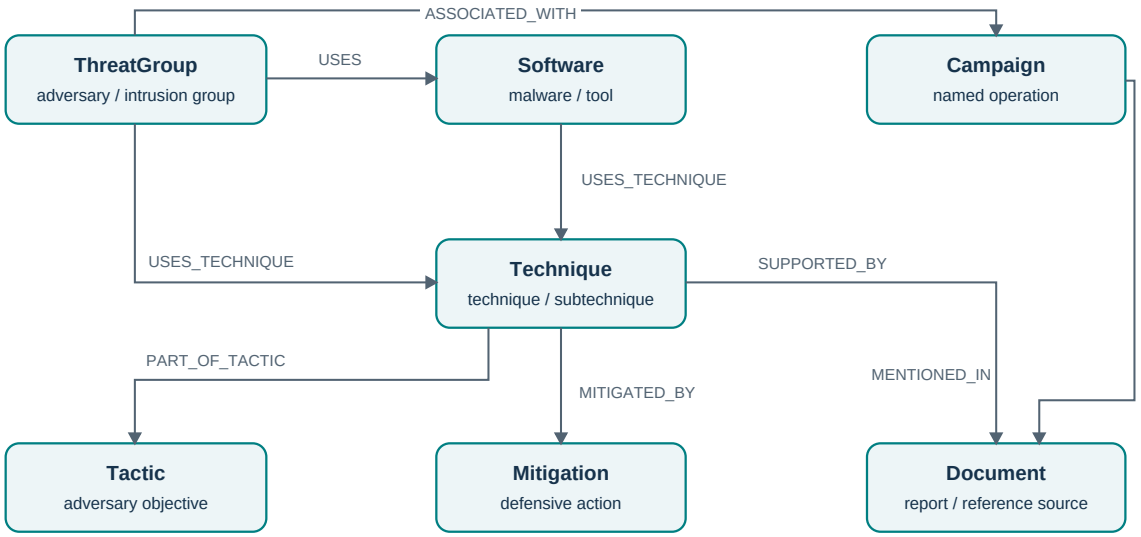

Figure 1. Core directed ontology. Campaign-to-Document illustrates MENTIONED_IN, which is allowed from every domain entity. Technique-to-Document illustrates SUPPORTED_BY evidence links. All factual edges also retain their own supporting source IDs. Arrows specify allowed schema paths, not asserted real-world facts.

Constraints and attributes. Nodes require unique canonical_id, name, and type; optional attack_id, aliases, description, and STIX ID preserve domain identity. Documents require URL, date, and source. Typed endpoints follow Figure 1; unsupported pairs are rejected. MENTIONED_IN records entity occurrence only. SUPPORTED_BY links an entity to evidence for a specific attribute claim, with claim_key and evidence_text; neither implies a relation between co-mentioned entities. Factual edges separately require source_doc_id, chunk_id, evidence_text, origin (extracted/fused), and validation_status. Model confidence is uncalibrated; uncertain aliases require review.

5. Proposed GraphRAG System Architecture

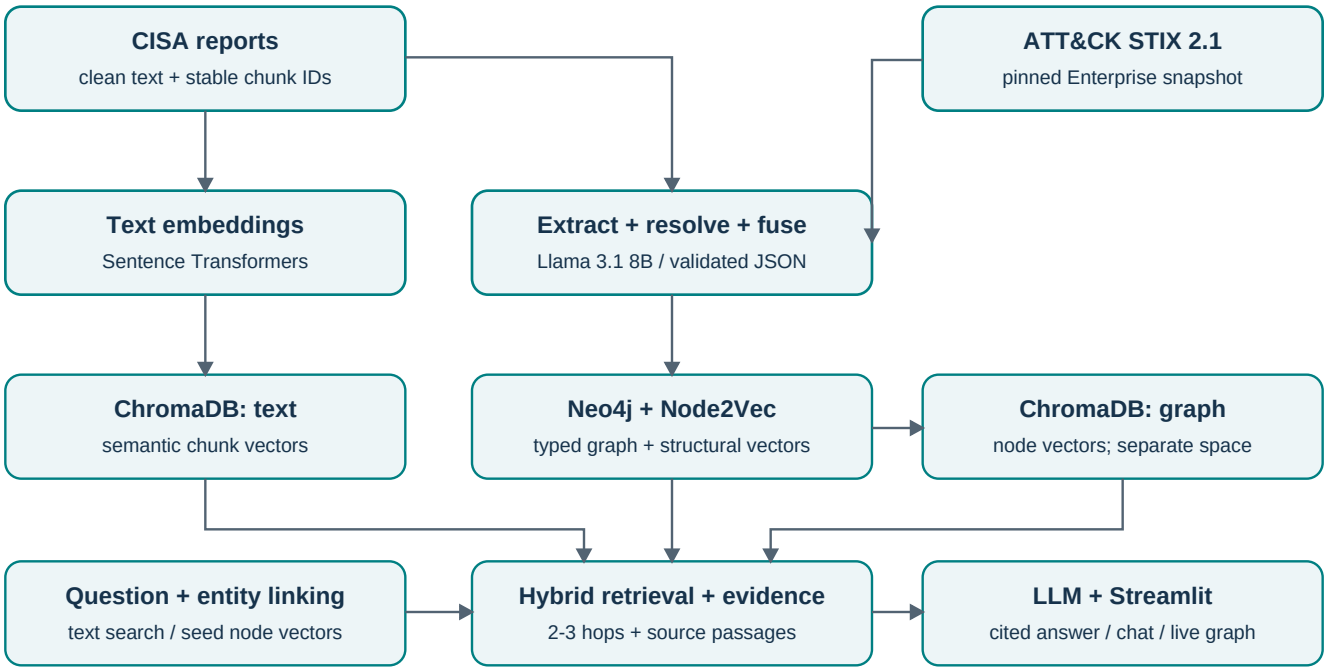

Figure 2. Offline construction (upper rows) and online retrieval/generation (bottom row). Neo4j retains typed relations and provenance; ChromaDB stores text and graph vectors separately. Retrieved graph edges lead back to their source passages.

(a) LLM extraction. I will use Llama 3.1 8B through Ollama with 400-600-token chunks and about 60-token overlap. Few-shot prompts will specify typed endpoints, evidence spans, and constrained JSON. The pipeline will validate syntax, IDs, types, and source evidence; retry malformed output once; then log failures. I will cache results and record model, prompt, and settings. A five-document timing test will establish feasible local throughput.

(b) Graph enhancement and verification. I will resolve ATT&CK IDs first, then verified aliases and normalized names. The pipeline will fuse relevant STIX relations into Neo4j, reverse mitigation edges into Technique MITIGATED_BY Mitigation, and map tactic membership. Extracted and fused origins will remain distinct. I will score extraction before fusion so imported knowledge cannot inflate accuracy; ambiguous attributions will not be inferred from co-occurrence.

(c) Embedding and indexing. I will use all-MiniLM-L6-v2 text embeddings and 128-dimensional Node2Vec vectors [3]. An undirected domain-graph projection will exclude Document hubs; Neo4j will retain original types and directions. Initial walks will use length 20, ten walks/node, p=q=1, and a fixed seed. Separate ChromaDB collections will preserve the two vector spaces. I will tune only on development queries and rebuild embeddings after freezing the graph.

(d) Retrieval and generation. The system will embed each question for text search and link explicit IDs or unambiguous aliases to seed nodes. Seed Node2Vec vectors will retrieve structural candidates; text vectors will never query that space. Initial limits are five text hits, five neighbors per seed, three hops, and 3,000 context tokens. Rank-based fusion will merge evidence rankings after typed-path validation and provenance lookup. The system will deduplicate passages and fall back to text when linking is uncertain; similarity alone will never establish a factual relation.

The generator will answer only from supplied evidence, cite source IDs, and state when evidence is insufficient or conflicting. Streamlit will provide chat history, retrieval-context inspection, and an interactive subgraph updated for each query. A first end-to-end slice will be built early, then expanded to the full frozen corpus.

6. Evaluation & Benchmarking Strategy

Extraction quality. I will normalize IDs/direction, deduplicate predictions, and calculate micro precision = TP/(TP+FP), recall = TP/(TP+FN), and F1 = 2PR/(P+R) on held-out passages. True positives must match gold endpoints and predicate with valid evidence. I will report relation-level counts, aggregate scores, and failure examples; fused edges will be excluded. Zero-denominator cases will be explicitly marked rather than silently dropped.

Configuration	Retrieved evidence / purpose
Text-only RAG (baseline)	Semantic passages only; conventional vector retrieval.
Graph-only retrieval (ablation)	Seed-linked graph paths and their provenance passages; no semantic chunk search.
Hybrid GraphRAG (full system)	Semantic passages + Node2Vec candidates + graph traversal + provenance.
Hybrid without Node2Vec (ablation)	Same pipeline with structural-vector expansion disabled; isolates embedding contribution.

Fair comparison. I will hold questions, generator/settings, embeddings, and context-token limits constant. The baseline will receive the same CISA and relevant ATT&CK evidence as text, separating retrieval effects from access to extra knowledge. I will select settings on development questions, isolate held-out labels, and log latency, retrieved IDs, paths, and answers. Four configurations across 20 questions require at least 80 scored answers.

Measure	Operational definition
Faithfulness / answer relevance	RAGAS evaluators [4] assess support in retrieved context and relevance to the question.
Context recall	RAGAS reference-based recall checks whether retrieved evidence supports the required reference-answer facts.
Hallucination rate	Custom claim audit: unsupported factual claims / all factual claims; also report the fraction of answers with any unsupported claim.
Human factuality, completeness, coherence	Each dimension scored 1-5 against reference answers and evidence for all 20+ questions in every configuration.

Human scoring protocol. I will conceal system labels and randomize answers. Factuality anchors are **1**: major unsupported claims, **3**: mixed support, **5**: all claims supported. Completeness anchors are **1**: few required facts, **3**: about half, **5**: all required facts. Coherence anchors are **1**: contradictory reasoning, **3**: understandable with gaps, **5**: clear, consistent links. Scores 2/4 fall between anchors. I will request an independent review of five questions across configurations if a volunteer is available; otherwise, I will re-score 25% after a delay and report single-rater limitations.

Analysis and success criteria. I will report paired differences, distributions, and bootstrap intervals, with small-sample limitations. Evaluator versions/prompts will be logged; I will manually audit unsupported-claim judgments and scoring disagreements. Abstentions will count toward completeness/relevance and be reported separately. Proposed targets are extraction F1 >= 0.80 and hybrid completeness at least 0.5/5 above baseline without lower mean factuality or faithfulness. These are targets, not claimed results. I will classify failures by extraction, linking, retrieval, and generation, and report negative findings.

7. Technical Risk Analysis & Mitigation

Risk / trigger	Actionable mitigation
False triples or weak evidence	Validate JSON and ontology; require evidence spans; audit low-confidence records and preserve rejected-output logs.
Ambiguous aliases or sparse graph	Merge only with reliable identifiers; review conflicts. Pilot overlapping reports and inspect connected paths before freezing the corpus.
Weak Node2Vec signal	Retain typed Neo4j traversal; exclude provenance hubs from embedding projection; quantify impact with the no-Node2Vec ablation.
Conflicting or excessive context	Cap hop depth and candidate count; deduplicate passages; preserve source dates and origins and surface unresolved disagreement.
Slow local inference / solo schedule	If pilot throughput threatens Oct. 10, cap corpus at 15 and cache extraction; preserve embeddings, UI, and evaluation. No new features after Oct. 10.
Evaluation bias or data leakage	Freeze held-out labels and settings; score extraction before fusion; blind answer labels and disclose single-rater limitations.

8. Project Timeline & Phase-Wise Milestones

I will lead every milestone. The working hybrid pipeline is targeted for **October 10**, preserving the final week for evaluation, documentation, and the October 17 deadline.

Dates (2026)	Milestone and completion gate
Sept. 27-29	M1 - Final proposal; select corpus and pin ATT&CK; freeze ontology and annotation protocol; begin gold labels.
Sept. 30-Oct. 3	M2 - Validated extraction and Neo4j; five-document pilot, initial QA slice, and architecture-report outline.
Oct. 4-6	M3 - Entity resolution and data fusion; complete 50+ gold triples and 20+ QA items; freeze evaluation sets.
Oct. 6-8	M4 - Text/Node2Vec indexes; reproducible checks; draft architecture report and evaluation scripts.
Oct. 8-10	M5 - Hybrid retrieval and cited generation; Streamlit history, context display, and retrieved-subgraph visualization.
Oct. 11-17	M6 - Oct. 11-13: score baseline/ablations. Oct. 14-15: finish two 6-8-page reports, code documentation, and slides. Oct. 16: rehearse 15-minute demo. Oct. 17: buffer and submit.

Presentation pitch. ThreatWeave makes the connections behind a CTI answer inspectable. I will explain the analyst problem, trace one question through source evidence and graph paths, compare the baseline answer, and close with measured results and limitations. A rehearsed example and saved run will support the live demonstration.

References

[1] CISA. Cybersecurity Advisories. cisa.gov/news-events/cybersecurity-advisories.

[2] MITRE. ATT&CK STIX Data (STIX 2.1). github.com/mitre-attack/attack-stix-data.

[3] Grover, A., and Leskovec, J. (2016). node2vec: Scalable Feature Learning for Networks. arxiv.org/abs/1607.00653.

[4] Ragas. Available metrics. docs.ragas.io - metric definitions.